

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO3: Analyze network services using port scanning, ping sweeps, and enumeration techniques across different operating systems to identify vulnerabilities. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50

Port Scanning Challenge

1. How would you identify and prioritize vulnerabilities after discovering multiple open ports during a port scan? Explain your approach.
2. A SYN scan and a TCP Connect scan produce different results on the same target. What factors could cause this difference, and how would you verify the findings?
3. During a port scan, most ports appear as "filtered." What security mechanisms might be responsible, and what additional techniques would you use to gather more information?
4. Compare TCP, UDP, and stealth (SYN) port scanning techniques. In which scenarios would each be the most effective, and what are their advantages and limitations?
5. Suppose you are conducting an authorized security assessment and discover critical services (such as SSH, FTP, and database ports) exposed to the internet. How would you assess the risks and recommend mitigation strategies?

Code of Conduct:

I ___M Kavya 192472370___ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.

I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: kavya

PORT SCANNING CHALLENGE

1. Identifying and Prioritizing Vulnerabilities After a Port Scan

After discovering multiple open ports, I would first identify the services and versions running on those ports using service enumeration. I would then compare the detected versions with known vulnerabilities using CVE databases and security advisories.

I would prioritize vulnerabilities based on **severity, exploitability, exposure, and business impact**. Internet-facing services, remotely exploitable vulnerabilities, weak authentication, and critical services would receive the highest priority. For example, an outdated database exposed directly to the Internet would be considered more critical than a low-risk internal service.

The process would be:

1. Identify open ports and services.
2. Determine service versions and operating system details.
3. Map vulnerabilities to CVEs and severity ratings.
4. Check whether the vulnerability is remotely exploitable.
5. Assess the possible impact such as data loss, unauthorized access, or service disruption.
6. Prioritize critical and high-risk findings for immediate remediation.
7. Validate the findings and document the results.

Thus, port scanning provides the initial attack surface, while enumeration and vulnerability analysis help determine which weaknesses require immediate attention.

2. Difference Between SYN Scan and TCP Connect Scan

A **SYN scan** sends a SYN packet and analyzes the response without completing the TCP three-way handshake. A **TCP Connect scan** completes the full TCP handshake using the operating system's networking stack.

Different results can occur because of:

- Firewall or IDS/IPS filtering.
- Network latency or packet loss.
- Different firewall rules for incomplete and completed connections.
- Rate limiting.
- Service behavior or TCP stack differences.
- Privilege limitations when performing a SYN scan.

To verify the findings, I would repeat the scan using both methods, check the target from an authorized

network position, perform service/version detection, and compare the results with firewall or system logs where available.

Therefore, a difference between the two scans should not immediately be considered a vulnerability; it must be validated using multiple techniques.

3. Why Most Ports Appear as "Filtered"

A port is shown as **filtered** when the scanner cannot determine whether the port is open because packets are being blocked or dropped.

Possible causes include:

- Firewalls and packet-filtering rules.
- IDS/IPS systems.
- Network Access Control mechanisms.
- Cloud security groups.
- Host-based firewalls.
- Routers or security appliances.
- Rate limiting or intrusion-prevention policies.

To gather additional information during an authorized assessment, I would use different scan techniques, perform service/version detection where permitted, check DNS and network configuration, compare results from different authorized network locations, and examine firewall or IDS logs with administrator permission.

A filtered result itself does not mean that a service is secure. It mainly indicates that the scanner's probes are being prevented from obtaining a clear response.

4. Comparison of TCP, UDP and SYN Scanning

Scan Type	Working Principle	Best Use	Advantages	Limitations
TCP Connect	Completes the TCP handshake	When SYN scanning is unavailable	Reliable and easy to perform	More noticeable and slower
UDP Scan	Sends UDP probes and analyzes responses	Finding DNS, DHCP, SNMP and other UDP services	Detects UDP-based services	Slower and results can be difficult to interpret

SYN Scan	Sends SYN and analyzes SYN/ACK or RST without completing the connection	General authorized security assessments	Fast, efficient and produces less application-level activity	May require privileges and can still be detected
-----------------	---	---	--	--

TCP Connect scanning is useful when reliability is more important or raw-packet privileges are unavailable. **UDP scanning** is essential when assessing services that operate over UDP. **SYN scanning** is generally effective for quickly identifying TCP services while reducing completed connections.

Using more than one technique provides better coverage because each method has different strengths and limitations.

5. Risk Assessment of Internet-Exposed SSH, FTP and Database Services

If SSH, FTP and database ports are directly exposed to the Internet, I would first determine whether each service is actually required and identify its version, configuration, authentication method and access requirements.

Risk Assessment

SSH:

SSH can be secure when properly configured, but weak passwords, outdated versions, unrestricted access and poor authentication controls can increase the risk of unauthorized access.

FTP:

Traditional FTP can transmit credentials and data without adequate encryption. It may therefore expose sensitive information to interception.

Database Services:

Internet-facing database ports are high-risk because attackers may attempt credential attacks, exploit software vulnerabilities, or access sensitive data if authentication or configuration is weak.

Recommended Mitigations

- Restrict Internet access to only required services.
- Use firewall rules and network segmentation.
- Allow SSH access only from trusted IP addresses or through a VPN where appropriate.
- Prefer strong authentication and disable unnecessary password-based access.
- Replace insecure FTP with secure alternatives such as SFTP.
- Keep operating systems and services patched and updated.

- Use strong, unique credentials and least-privilege permissions.
- Disable unnecessary services and ports.
- Enable logging, monitoring and intrusion detection.
- Regularly perform vulnerability assessments and configuration reviews.

The highest priority should be given to **unnecessary Internet exposure, vulnerable versions, weak authentication, and database services containing sensitive information**. The objective is to reduce the attack surface while maintaining only the services required for legitimate business operations.

RUBRICS FOR CALCULATION:

Criteria	Weightage	(Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Identification of Port Scanning Factors	25%	Clearly identifies comprehensive and relevant strengths, weaknesses, opportunities, and threats	Identifies most factors with minor gaps	Limited or partially relevant identification	Incorrect or incomplete Port Scanning factors
Analysis	25%	Provides deep, insightful analysis of each Port Scanning component with strong reasoning	Provides good analysis with some depth	Basic analysis with limited reasoning	No meaningful analysis provided
Linkage	20%	Effectively links Port Scanning elements to derive strong strategic insights and implications	Shows some linkage with moderate insights	Weak linkage; limited strategic thinking	No linkage or strategic insight

Application	20%	Applies Port Scanning analysis effectively to the given case or scenario with clear relevance	Applies analysis with minor gaps	Limited application; lacks clarity	No clear application to context
Clarity	10%	Well-structured, clear, and logically presented with proper formatting	Generally clear with minor issues	Some structure but lacks clarity	Poorly organized and difficult to understand